

Report Cybersecurity

Bisogna trovare le vulnerabilità e poi capirle

Bisogna classificare le vulnerabilità, selezionarne un paio e fornire la penetration

Penetration Testing Report

SI da a chi commissiona

Executive Summary: spiegazione del livello di vulnerabilità dell'infrastruttura

- Target non tecnico -> spiegazione formale/professionale, informazioni tecniche non richieste (target manager)
- Sintetico e conciso
- Scopo del test
- risultati
- metodologia e obiettivi
- problematiche
- contromisure scritte in maniera sintetica
- Analisi del rischio dell'asset (sintetico)
- Effettuare subito una riduzione del rischio
- Regole di ingaggio: definiamo gli accordi preliminari
- requisiti legali e operativi stabiliti prima del test
- esecuzione: framework generale per il pentesting
- obiettivi
- ruoli (analista tecnico)
 - Portare a termine l'attività
 - Non uscire fuori dai confini dell'attività di pentesting
- Vulnerability report:
- Descrizione delle vulnerabilità
- Vulnerabilità che abbiamo riscontrato e trovato tramite i tool e daremo una nomenclatura alle vulnerabilità
- grado di impatto
- Descrizione breve

Remediation report: contromisure

- Ridurre il rischio e rafforzare l'asset
- Deve essere chiaro e diretto al punto
 - Scrivere tutto in modo schematico andando al punto

Findings Summary

- Evidenze emerse dall'attività di pentesting
- Focus tecnico: rivolta alla sicurezza dell'infrastruttura
 - Può dare più informazioni su come risolvere il problema in modo più tecnico
 - Supporto alla remediation:
 - Contromisure tecniche adeguate
Detailed Summary
- Analisi tecnica dettagliata per ogni vulnerabilità rilevata
- Origini della vulnerabilità
- Modalità di scoperta della vulnerabilità (es. openvas o nessus o entrambi)
- Cause
- Rischi e impatti sull'asset
- Contromisure
- Classificazione del rischio

Metodologie Utilizzate PT

L'idea è quella di ricreare l'attività di pentesting ottenendo lo stesso risultato.

1. Introduzione

1. Sezione introduttiva delle metodologie

1. Fasi del framework - Potrebbe non essere come ci è stato spiegato

2. Linguaggio chiaro e comprensibile e tecnico

2. Fasi del FGPT

1. Come è stato scoperto l'asset e definizione della superficie d'attacco

2. Tool utilizzati e come utilizzarli

1. Comandi utilizzati

2. Output di tali comandi

3. Considerazioni finali

1. Excursus dell'attività

2. Linguaggio non tecnico (non obbligatorio)

1. Meglio tecnico

3. Sintetico

Work Package tasks

- Introduzione
- Obiettivi
- Strumenti utilizzati
- Information Gathering e Target Discovery
- Enumeration and port scanning
- vulnerability mapping
- Target Exploitation

- Considerazioni finali

1. Obiettivi del progetto

1. Valutazione sulla qualità della sicurezza del sistema in esame

2. Strumenti utilizzati

1. Struttura macchina virtuali
2. Ambiente non servono informazioni come indirizzo IP e altre info

3. Netdiscover

4. Nmap scan sulla sottorete

1. Si usa un fingerprint attivo e poi passivo (-O)

5. Aggiornamento topologia della rete (adesso con IP e MAC address)

6. Active enumeration target con `nmap -sV <IP target> -p- -oX TPC_WH_SCAN.xml`

1. Dice quali sono le porte attive sulla macchina target
2. Già dalla versione si può capire la vulnerabilità

7. Scansione UDP

8. Per enumerare si può utilizzare `nmap -A <IP> -p- -oX AGG_TCP_WH7_SCAN.xml`

9. Si prende l'host e ci si prova a connettere tramite uno dei servizi trovati

1. Andiamo a scannerizzare tutta la directory del sito con `dirbuster` per capire se ci sono vulnerabilità

10. Nessus e Owasp-Zap

11. Burp suite (da vedere) per web applications

12. `sqlmap -r sqlinternetnetwork -p user --current-user`

13. `sqlmap -r sqlinternetnetwork -p user --dump`

14. Tentativo di entrare nella macchina con msf

1. Hermitage - msfconsole ma grafico
- 2

DEMO DOCUMENTAZIONE CYBER

METODOLOGIE PT

Lo stile del documento rispecchia quello che è stato fatto

Fare tutto come se fosse una cosa discorsiva

- Sommario
 - Spunti al lettore come le fasi, l'ambiente etc.
- Indice
 - Varie parti del documento da fare bene
 - Elenco delle figure
- Capitolo 1
 - Descrione della situazione e strumenti utilizzati
- Capitolo 2
 - Tutto l'information gathering

- Passi e strumenti
 - Mostrare volutamente i passi
- Tutti i comandi con descrizione
- Os fingerprint passivo e attivo
 - Come è stato fatto e perché è stato usato questo o quel comando e gli output
 - Informazioni ricavate
- Aggiornamento topologia della rete dopo i test
- Capitolo 2
 - Comando e output
 - Tutti i passi
- Capitolo 4
 - Tutte le vulnerabilità
- Capitolo 5
 - Target exploitation
 - Come è stato identificato il processo di exploitation
- Capitolo 6
 - Considerazioni finali

PT REPORT

L'attività deve essere acilmente riproducibile, bisogna specificare quali strumenti hanno rilevato le vulnerabilità.

Se due o più tool coprono le stesse vulnerabilità, allora potrebbe

Fisso, le parti sono quelle e bisogna rimanere fedeli

Non ci vanno screenshot di comandi o scansioni di openvas o nessus

Non ci devono essere elementi specifici ai comandi per quello c'è l'altro documento

- Sommario per dare concretezza al documento
- Indice
- Executive summary cosa fare
 - Regole di ingaggio
 - Vulnerability report
 - Quali sono le più fastidiose e quali più focalizzazione (riassunto)
- Remediation report
 - Veloce e preciso e affidabile
- Finding summary
 - Come vengono catalogate le vulnerabilità
 - Convenzioni
- Detailed summary
 - Catalogazione delle vulnerabilità in maniera precisa e dettagliata
 - Critic, medium, low, information vulnerability

- Riferimenti alle CVE bibliografici